SECCIÓN 6.2

Validación inicial y criterios para escalar

Temas de esta sección:

- Qué significa validar antes de escalar (sin resolver todo el incidente)
- Escalamiento débil vs escalamiento útil: la diferencia práctica
- Información mínima para un escalamiento de calidad
- Qué evidencia justifica escalamiento urgente y qué no
- Cuándo escalar aunque falte información
- Plantilla de escalamiento y tres ejemplos aplicados

Validar no significa resolver el incidente. Significa reunir la evidencia mínima necesaria para tomar una decisión con criterio: cerrar, monitorear o escalar.

Lo que validar INCLUYE

- Confirmar la alerta original y qué evento la disparó
- Identificar usuario, host y fuente de la alerta
- Revisar la acción del control (Allowed/Blocked)
- Buscar actividad previa y posterior relacionada
- Consultar reputación del indicador
- Verificar si existe ticket o cambio que justifique
- Evaluar criticidad del activo y del usuario
- Documentar las limitaciones de lo que no se pudo revisar

Lo que validar NO implica

Resolver el incidente completo antes de escalar
Esperar evidencia perfecta para tomar una decisión
Confirmar malware o compromiso antes de avisar
Ejecutar acciones de contención sin autorización
Hacer un análisis forense completo del endpoint
Entrevistar al usuario antes de documentar
Escribir un informe detallado antes de escalar
Esperar la respuesta de IT para registrar lo observado

Escalar no es confirmar incidente. Es reconocer que la evidencia disponible muestra riesgo suficiente para requerir revisión avanzada.

ESCALAMIENTO DÉBIL

```
"PowerShell sospechoso. Revisar."
```

- No identifica usuario ni host
- No muestra command line
- No dice si fue permitido
- No indica actividad posterior
- No explica por qué importa
- No propone próximos pasos

ESCALAMIENTO ÚTIL

```
Se observó powershell.exe iniciado por WINWORD.EXE
en FIN-LAP-022 (finanzas.paz). Command line:
-nop -w hidden -enc. Acción: Allowed.
Posteriormente: C:\Public\update.exe + conexión a
billing-check-update.net. Sin ticket identificado.
Recomendación: análisis del archivo y posible
aislamiento del endpoint.
```

- Incluye activo y usuario
- Muestra command line completa
- Indica que fue permitida
- Detalla actividad posterior
- Explica por qué importa
- Propone acción concreta

6.2 | Calidad de evidencia y criterios de escalamiento

No toda evidencia tiene el mismo peso. La calidad decide cuándo escalar:

EVIDENCIA MÁS DÉBIL	EVIDENCIA MÁS FUERTE
Nombre de alerta genérico	**Process tree completo con command line**
Score alto sin detalles técnicos	**Archivo creado y ejecutado desde ruta pública**
Dominio raro consultado una vez	**Persistencia (Run Key, tarea, servicio)**
Reputación dudosa sin contexto	**Conexión externa permitida y periódica**
Evento aislado sin actividad posterior	**Regla de correo externa creada post-login**
Usuario dice 'creo que fui yo'	**Mismo indicador en múltiples hosts**
	Varias fuentes que coinciden

No siempre se necesita evidencia perfecta para escalar. Si el activo es crítico y el riesgo es alto, escalar con limitaciones documentadas.

6.2 | Cuándo escalar aunque falte información

No esperar certeza perfecta. Escalar con limitaciones documentadas cuando el riesgo lo justifica:

El activo es crítico

Servidor de pagos, DC, sistema de autenticación o portal de clientes con actividad sospechosa — aunque la evidencia sea débil. El impacto potencial justifica la alerta.

La amenaza puede propagarse rápido

Indicador en múltiples hosts, ransomware posible, cuenta privilegiada comprometida. Esperar más evidencia puede permitir que el daño se expanda.

No se puede obtener más evidencia

Sin EDR, sin visibilidad en el servidor, sin acceso a logs de identidad. La limitación es la razón para escalar, no para cerrar.

La actividad posterior es inusual

Login anómalo seguido de regla de correo + descarga masiva. Cada evento aislado podría ser ruido; la secuencia combinada justifica escalar.

Regla práctica: escalar con lo que tenés, documentando explícitamente qué falta. Es mejor un escalamiento con limitaciones que esperar en silencio ante una amenaza activa.

6.2 | Plantilla de escalamiento y tres ejemplos

Plantilla breve — adaptable a ticket, mail o chat operativo:

```
Resumen:
[Qué ocurrió]

Evidencia:
[Eventos + timestamps]

Contexto:
[Usuario, host, criticidad]

Riesgo:
[Por qué importa]

Validaciones:
[Qué se revisó]

Limitaciones:
[Qué falta]

Acción recomendada:
[Cerrar/escalar/contener]
```

ENDPOINT	IDENTIDAD	SERVIDOR WEB
WINWORD→PS -enc en FIN-LAP-022 (fin.paz). Creó update.exe en C:\Public\ + conexión a billing-check-update.net. Sin ticket. → Análisis del archivo y evaluación de aislamiento.	legal.romero: impossible travel, device Unknown, MFA ok. Luego: regla de reenvío externa + OAuth Read Mail/Files + 1,200 archivos SharePoint. → Revocación sesiones, revisión OAuth, escalamiento identidad/IR.	WEB-PAY-01: WAF Command Injection (Alert Only, HTTP 200), w3wp.exe→cmd.exe→whoami, shell.aspx en /uploads. Servidor productivo. → Escalamiento urgente IR/apps/infra/negocio. Preservar evidencia.